

如图 1-2 和表 1-1 所示。下面分 3 个阶段对威胁进行分析：①基本的威胁；②主要可实现威胁；③潜在威胁及分类。

## 1.2.2 安全威胁的来源

### 1. 基本威胁

下面 4 种基本安全威胁直接反映本章开篇时所划分的 4 个安全目标：

(1) **信息泄漏**：信息被泄漏或透露给某个非授权的人或实体。这种威胁来自诸如窃听、搭线或其他更加错综复杂的信息探测攻击。

(2) **完整性破坏**：数据的一致性通过非授权的增删、修改或破坏而受到损坏。

(3) **拒绝服务**：对信息或资源的访问被无条件地阻止。这可能由以下攻击所致：攻击者通过对系统进行非法的、根本无法成功的访问尝试使系统产生过量的负荷，从而导致系统的资源在合法用户看来是不可使用的。拒绝服务也可能是因为系统在物理上或逻辑上受到破坏而中断服务。

(4) **非法使用**：某一资源被某个非授权的人或以某种非授权的方式使用。例如，侵入某个计算机系统的攻击者会利用此系统作为盗用电信服务的基点，或者作为侵入其他系统的“桥头堡”。

### 2. 主要的可实现威胁

在安全威胁中，主要的可实现威胁应该引起高度关注，因为这类威胁一旦成功实施，就会直接导致其他任何威胁的实施。主要的可实现威胁包括渗入威胁和植入威胁。

主要的渗入威胁有如下几种：

(1) **假冒**。某个实体（人或系统）假装成另外一个不同的实体。这是突破某一安全防线最常用的方法。这个非授权的实体提示某个防线的守卫者，使其相信它是一个合法实体，此后便攫取了此合法用户的权利和特权。黑客大多采取这种假冒攻击方式来实施攻击。

(2) **旁路控制**。为了获得非授权的权利和特权，某个攻击者会发掘系统的缺陷和安全漏洞。例如，攻击者通过各种手段发现原本应保密但又暴露出来的一些系统“特征”。攻击者可以绕过防线守卫者侵入系统内部。

(3) **授权侵犯**。一个授权以特定目的使用某个系统或资源的人，却将其权限用于其他非授权的目的。这种攻击的发起者往往属于系统内的某个合法的用户，因此这种攻击又称为“内部攻击”。

主要的植入类型的威胁有如下几种：

(1) **特洛伊木马 (Trojan Horse)**。软件中含有一个不易觉察的或无害的程序段，当被执行时，它会破坏用户的安全性。例如，一个表面上具有合法目的的应用程序软件，如文本编辑软件，它还具有一个暗藏的目的，就是将用户的文件复制到一个隐藏的秘密文件中，这种应用程序就称为特洛伊木马。此后，植入特洛伊木马的那个攻击者就可以阅读到该用户的文件。

(2) **陷门 (Trapdoor)**。在某个系统或其部件中设置“机关”，使在提供特定的输入

数据时，允许违反安全策略。例如，如果在一个用户登录子系统上设有陷门，当攻击者输入一个特别的用户身份号时，就可以绕过通常的口令检测。

### 3. 潜在威胁

在某个特定的环境中，如果对任何一种基本威胁或主要的可实现的威胁进行分析，就能够发现某些特定的潜在威胁，而任意一种潜在的威胁都可能导致一些更基本的威胁发生。例如，在对信息泄漏这种基本威胁进行分析时，有可能找出以下几种潜在的威胁：

- (1) 窃听（Eavesdropping）。
- (2) 流量分析（Traffic Analysis）。
- (3) 操作人员的不慎所导致的信息泄漏。
- (4) 媒体废弃物所导致的信息泄漏。

图 1-2 列出了一些典型的威胁及它们之间的相互关系。注意，图中的路径可以交错。例如，假冒攻击可以成为所有基本威胁的基础，同时假冒攻击本身也存在信息泄漏的潜在威胁。信息泄漏可能暴露某个口令，而用此口令攻击者也可以实施假冒攻击。表 1-1 列出了各种威胁之间的差异，并分别进行了描述。

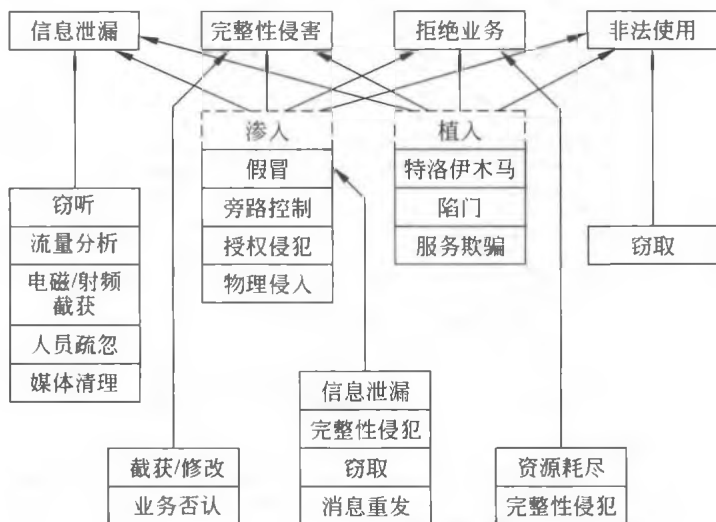


图 1-2 典型的威胁及其相互关系

对 3000 种以上的计算机误用案例所做的一次抽样调查显示，最主要的几种安全威胁如下（按照出现频率由高至低排列）：

- (1) 授权侵犯。
- (2) 假冒攻击。
- (3) 旁路控制。
- (4) 特洛伊木马或陷门。
- (5) 媒体废弃物。

在 Internet 中，网络蠕虫（Internet Worm）就是将旁路控制与假冒攻击结合起来的一种威胁。旁路控制就是利用已知的 UNIX，Windows 和 Linux 等操作系统的安全缺陷，